

SSL

ISS

Activar el ISS

- 1) Inicio > Panel de control > Programas > Programas y características
- 2) **"Activar o desactivar las características de Windows"**
- 3) Selecciona la casilla de **Internet Information Services** (OPCIONES POR DEFECTO)
- 4) Abrir **Protocolos y Puertos** adecuados mediante Firewall de Windows
- 5) **"Firewall de Windows Defender"**
- 6) **"Permitir una aplicación o una característica a través de Firewall de Windows Defender"**
- 7) **"Cambiar la configuración"**
- 8) Seleccionar (PRIVADO Y PUBLICO) AMBOS:
 - a. Servicios World Wide Web (HTTP)
 - b. Servicios seguros World Wide Web (HTTPS)
- 9) Panel de control > Herramientas de Windows > Administrador de IIS o **inetmgr** (si queremos mirar la administración del ISS)

Trampas de Examen y Errores Comunes:

- **Olvidar el puerto HTTPS en el Firewall:** Esta es una pregunta/fallo clásico de examen. Muchos alumnos instalan IIS, prueban la conexión básica por HTTP (puerto 80) y ven que funciona, pero luego fracasan en la parte de certificados. Si no marcas "Servicios seguros World Wide Web (HTTPS)", el Firewall bloqueará cualquier intento de conexión por el puerto 443, haciendo inútil tu certificado SSL

CARGAR UN CERTIFICADO PARA EL SERVIDOR

Abrir administrador

Seleccionar la opción "Certificados de servidor"

Importar archivo de certificado tiene que ser .pfx ya que contiene clave privada

Conserpfx -> Contraseña del certificado del servidor : *zpSERas.pfx*

Una vez que se importa el certificado esta en el Administrar certificados de Equipo **certlm.msc**

Carga el certificado de la autoridad certificadora, zpac.as, en el almacén "Entidades de certificación raíz de confianza" del "equipo local".

Debe ser en .cer nunca en .pfx dado que es lo que contiene para verificar que nuestro servidor es de confianza :

 **Trampa de Examen (¡Pregunta de oro!):** Si el profesor te pregunta en el examen: "¿Qué pasaría si distribuyes e importas el archivo .pfx de la Autoridad Certificadora en los equipos de los usuarios para que confíen en ella?"

Tu respuesta debe ser: "Estaríamos comprometiendo toda la seguridad de la red. Al darles el .pfx, les estamos dando la clave privada de la Autoridad Certificadora. Con esa clave privada, cualquiera podría generar certificados falsos a nombre de Google, del banco o de nuestra empresa, y nuestro equipo confiaría en ellos ciegamente

CREACIÓN DE UN SERVIDOR WEB SEGURO

- 1) Crea una carpeta física en tu disco duro para la web, por ejemplo:
%SystemDrive%\inetpub\wwwroot\seg.
- 2) En IIS, haz clic derecho sobre "Sitios" y elige **Agregar sitio web....**
- 3) **Nombre del sitio:** zpser.as (o el nombre exacto para el que fue emitido tu certificado).
- 4) **Ruta física:** La carpeta que acabas de crear.
- 5) **Enlace:** Cambia el tipo a **https** y el puerto a **443**.
- 6) **Certificado SSL:** Selecciona el certificado que importaste en el paso 1.

Los nombres del sujeto del certificado disponible debe ser el mismo que el nombre del sitio

Si no aparece sitio web F5

Crear frontend

- 7) "Examen de directorios" -> Habilitar

 **El Porqué:** Por defecto, esta opción viene deshabilitada por motivos de seguridad, para que un atacante no pueda ver un listado con la estructura interna de los archivos de tu servidor. Sin embargo, en un entorno de prácticas de laboratorio, se habilita porque resulta mucho más cómodo ver qué hay dentro de la carpeta directamente desde el navegador, en lugar de tener que escribir la URL exacta de cada archivo.

En el directorio C:\inetpub\wwwroot\seg\ se crea el archivo web.config que almacena las opciones de configuración del sitio web en formato XML. Para probar el servidor hay que utilizar una página .html

Para conocer la página a usar

- 8) Administrador de IIS > Página principal de zpser.as, seleccionar en el panel central la opción "Documento predeterminado" -> Generalmente: **"Default.htm"**

Seguridad del Servidor

"Configuración de SSL"

- "Requerir SSL" para habilitar un mecanismo de cifrado de datos con clave de 40 bits para proteger las comunicaciones entre el servidor y los clientes
- Determinar si autenticar o no al cliente

- **Omitir:** El servidor NO acepta certificados de cliente (opción predeterminada). Los clientes no tienen que probar su identidad al servidor antes de acceder a los contenidos.
- **Aceptar:** El servidor acepta certificados de cliente (si se proporcionan) y comprueba la identidad del cliente antes de permitirle el acceso a los contenidos.
- **Requerir:** El servidor requiere certificados de cliente para comprobar la identidad del cliente antes de permitirle el acceso a los contenidos.

PROBAR SI FUNCIONA EL SERVIDOR

Panel derecho de Acciones de la página principal del sitio web

Examinar sitio web, hay la opción “Examinar *:443 (https)”

PARAR EL SERVIDOR

Acciones -> Reiniciar/Iniciar/Detener

Preparación del Navegador (Cliente)

Verificación en el Navegador (Microsoft Edge):

- **Ruta en Edge:** Abre Edge, haz clic en el menú de los tres puntos (...) > **Configuración**.
- En el panel izquierdo, selecciona **Privacidad, búsqueda y servicios**.
- En el panel derecho, baja hasta la sección "Seguridad" y haz clic en **Administrar certificados**.
- **Administrar certificados importados desde Windows**
- Aparecerá una ventana igual a la de las opciones de Internet de Windows. Comprueba que el certificado de tu AC aparece en la pestaña **Entidades de certificación raíz de confianza**.

Otra opción es “Panel de Control” -> “Opciones de Internet”

Configuración adicional de EDGE:

En la sección “Borrar datos de exploración” utiliza la opción “Elegir que se debe borrar cada vez que se cierra el explorador” y selecciónalo todo

¿Por qué usamos certmgr.msc aquí y no certlm.msc? Porque ahora estamos configurando el ordenador como *usuario final* (cliente) que navega por internet, no como un servidor que ofrece un servicio de red. Queremos que nuestro navegador (que se ejecuta bajo nuestro usuario) confíe en la AC.

Pruebas cliente externo a VM

Pasos Técnicos y Comandos (UI):

1. Primera Prueba (Acceso por IP):

- En el navegador de tu máquina física, introduce la URL: `https://TU_IP_VIRTUAL` (ej. `https://192.168.0.192`).
- Aparecerá una pantalla roja de advertencia: "**Su conexión no es privada**".
- Si despliegas "Avanzado" o "Más información", verás el error específico: `NET::ERR_CERT_COMMON_NAME_INVALID`.

2. Segunda Prueba (Acceso por Dominio):

- Intenta usar el nombre correcto del sitio: `https://zpser.as`.
- El navegador dirá "**Vaya... no se puede obtener acceso a esta página**" (DNS no resuelto).

3. La Solución (Editar el fichero Hosts):

- En tu máquina física, busca el "Bloc de notas" en el menú Inicio.
- **CRÍTICO:** Haz clic derecho sobre él y selecciona "**Ejecutar como administrador**".
- Ve a Archivo > Abrir y navega hasta la ruta mágica: `C:\Windows\System32\drivers\etc`. (Asegúrate de cambiar el filtro abajo a la derecha a "Todos los archivos (.*)" o no verás nada).
- Abre el archivo llamado `hosts`.
- Al final del documento, añade una nueva línea con la IP de tu servidor virtual, un par de espacios (o tabulador) y el nombre del dominio:
 - `192.168.0.192 zpser.as` (Sustituye por tu IP real).
- Guarda el archivo.

4. Prueba Final Definitiva:

- Antes de probar, limpia la caché: abre **Opciones de Internet > Contenido > Borrar estado SSL**.
- Cierra y vuelve a abrir tu navegador.
- Entra en `https://zpser.as`.
- ¡Deberías ver tu página web con el codiciado candado de conexión segura!.

Firewall

Acceso al Firewall

Firewall de Windows Defender

Ubicaciones de Red

- **Red doméstica:** se usa cuando se conoce y se confía en los usuarios y equipos de la red. La "detección de redes" está activada en la ubicación redes domésticas, permitiendo que cada equipo de la red vea a todos los demás.
- **Red de trabajo:** se usa en pequeñas oficinas o en subredes de un lugar de trabajo. La detección de redes esta activada de forma predeterminada.
- **Red pública:** se usa para las redes de lugares públicos, como cafeterías o aeropuertos. Con esta ubicación la detección de redes está desactivada, lo que oculta el equipo a los otros equipos que están usando la red.
- **Dominio de red:** se usa en redes de dominio, en las que un equipo actúa como controlador de la red.

Para la configuración del firewall, las redes domésticas y de trabajo se tratan del mismo modo y se denominan redes privadas.

Configuración avanzada

Windows + r -> **wf.msc**

Las reglas de seguridad de conexión requieren que los dos equipos que se comunican dispongan de una directiva con reglas de seguridad de conexión (u otra directiva IPsec) que sea compatible con la del otro equipo

Crear una regla para aislar el equipo (Bloquear todo excepto una IP):

- Ve a **Reglas de salida > Nueva regla...** (panel derecho).
- Tipo de regla: **Personalizada**.
- Programa: **Todos los programas**.
- Protocolo y puertos: Tipo de protocolo **Cualquiera**.
- **Ámbito (¡El paso clave!):** * Direcciones IP locales: Cualquiera.
 - Direcciones IP remotas: **Estas direcciones IP**.
 - Para permitir que *solo* se conecte a la IP 192.168.1.200, debes añadir **dos rangos a bloquear**:
 - De 0.0.0.0 a 192.168.1.199.
 - De 192.168.1.201 a 255.255.255.255.
- Acción: **Bloquear la conexión**.
- Perfil: Todos.



Trampas de Examen y Errores Comunes:

- **Intentar abrir un puerto para el Ping:** ¡Pregunta de examen 100% segura! Muchos alumnos intentan crear una regla nueva abriendo un puerto TCP o UDP para que funcione el Ping. **El Ping no usa puertos**, trabaja en la capa de red usando el protocolo **ICMP** (Internet Control Message Protocol).

- **La lógica inversa al aislar una IP:** El Firewall permite todo el tráfico de salida por defecto. Si quieres permitir la salida *solo* a una IP, no creas una regla de "Permitir" para esa IP (porque ya está permitida). Tienes que crear una regla de "**Bloquear**" para **todo el resto de IPs de internet**, usando los rangos que dejan la IP objetivo justo en el medio.

💡 El Porqué (Justificación para el profesor):

- **¿Por qué el ping viene bloqueado por defecto?** En ciberseguridad, un equipo que responde a pings es un equipo "visible" que un atacante puede escanear en la red. Windows lo bloquea en redes públicas para mantener el equipo oculto (modo sigilo).
- **¿Por qué configuramos esto en "Reglas de salida"?** Porque estamos simulando un entorno de alta seguridad donde queremos controlar a dónde puede "llamar" nuestro equipo. Las reglas de entrada nos protegen de quien llama a nuestra puerta; las de salida evitan que software malicioso (o usuarios no autorizados) extraigan datos hacia servidores externos.

"Permite que la máquina virtual responda a Pings".

El error letal: El alumno va al Firewall, hace clic en "Nueva regla", selecciona "Puerto", y se queda en blanco porque **el Ping no tiene puerto**. Intenta inventarse uno (a veces abren el puerto 7 o buscan en Google "Ping port") y el ejercicio queda suspenso.

La solución correcta: * En el Firewall, no debes crear una regla de "Puerto", sino buscar en las reglas predefinidas la que maneja el protocolo **ICMPv4**.

- Específicamente, el Ping usa un tipo de mensaje de ICMP llamado **Petición de Eco (Echo Request)**. Habilitando esa regla, el "edificio" entero tiene permiso para responder cuando le gritan desde la calle, independientemente de qué puertas (puertos) tenga cerradas por dentro.